

Based on Scope Based Recon Methodology by Harsh Bothra (@harshbothra_)

Tg:@gitbook_s

Scope Based Recon

Small Scope

Only Specific URLs are part of Scope. This usually includes staging/dev/testing or single URLs. like: app.harshbothra.tech

Recon To-Do

- Directory Enumeration
- Technology Fingerprinting
- Port Scanning
- Parameter Fuzzing
- Wayback History
- Known Vulnerabilities
- Hardcoded Information in JavaScript
- Domain Specific GitHub & Google Dorking
- Broken Link Hijacking
- Data Breach Analysis
- Misconfigured Cloud Storage

Medium Scope

Usually the scope is wild card scope where all the subdomains are part of scope. like: Scope: *.harshbothra.tech

Recon To-Do

- Subdomain Enumeration
- Subdomain Takeover
- Probing & Technology Fingerprinting
- Port Scanning
- Known Vulnerabilities
- Template Based Scanning (Nuclei/Jeales)
- Misconfigured Cloud Storage
- Broken Link Hijacking
- Directory Enumeration
- Hardcoded Information in JavaScript
- GitHub Reconnaissance
- Google Dorking
- Data Breach Analysis
- Parameter Fuzzing
- Internet Search Engine Discovery (Shodan, Censys, Spyse, etc.)
- IP Range Enumeration (If in Scope)
- Wayback History
- Potential Pattern Extraction with GF and automating further for XSS, SSRF, etc.
- Heartbleed Scanning
- General Security Misconfiguration Scanning

Large Scope

Everything related to the Organization is a part of Scope. This includes child companies, subdomains or any labelled asset owned by organization.

Recon To-Do

- Tracking & Tracing every possible signatures of the Target Application (Often there might not be any history on Google related to a scope target, but you can still crawl it.)
- Subsidiary & Acquisition Enumeration (Depth – Max)
- Reverse Lookup
- ASN & IP Space Enumeration and Service Identification
- Subdomain Enumeration
- Subdomain Takeover
- Probing & Technology Fingerprinting
- Port Scanning
- Known Vulnerabilities
- Template Based Scanning (Nuclei/Jeales)
- Misconfigured Cloud Storage
- Broken Link Hijacking
- Directory Enumeration
- Hardcoded Information in JavaScript
- GitHub Reconnaissance
- Google Dorking
- Data Breach Analysis
- Parameter Fuzzing
- Internet Search Engine Discovery (Shodan, Censys, Spyse, etc.)
- IP Range Enumeration (If in Scope)
- Wayback History
- Potential Pattern Extraction with GF and automating further for XSS, SSRF, etc.
- Heartbleed Scanning
- General Security Misconfiguration Scanning
- And any possible Recon Vector (Network/Web) can be applied.